Threat Intelligence

Threat evolution in Q1 2019

APRIL 2019

group-ib.com

Contents

INTRODUCTION **3**

EXECUTIVE SUMMARY **4**

Targeted attacks on the financial sector 4

Financial threats 5

Data leaks 6

Threats to the government sector 6

FORECASTS FOR Q2 2019 **7**

ADVANCED THREATS IN THE FINANCIAL SECTOR **9**

FINANCIAL THREATS **17**

Malware for Android 18

Malware and threats for PC 21

Attacks on ATMs and POS terminals 31

PRO-GOVERNMENT APTS **35**

Data leaks 51

Introduction

Every quarter Group-IB releases a report on the development of high tech cyber-crime, featuring new tendencies, emerging trends and predictions on the cyber-threat landscape.

The most dangerous threats have been attacks on the financial sector. This report features threats with a particular focus on Europe, Russia, the USA, Canada and Australia. This document also provides a comprehensive description of threats to governments, including targeted attacks supported by government and significant data leaks.

To collect data and inform our clients, we analyse various botnets and malware while conducting incident response, monitoring underground forums and accumulating information on new trends, threats and data leaks. Every day we research thousands of compromised credentials, bank card numbers, hackers' accounts, messages and announcements on the dark web as well as tens of thousands of attacks, which enables us to promptly notify you of threats targeting your company and clients.

Executive summary

Targeted attacks on the financial sector

Q1 2019 saw the following APT campaigns against financial organisations:

- Cobalt continued their attacks sending out emails with links to documents containing a malicious macro. The attacks involved Coblnt, a malicious program that was installed on the victims' machines. One of the attacks was carried out under the name of an Interra Credit Union employee and targeted individuals well known in the financial sector. There was another email campaign that targeted European banks, and yet another one coming from a supposedly compromised server of the Indian bank Punjab & Sind Bank.
- A group of criminals that imitated Cobalt was discovered. The group launched a successful attack on a Maltese bank and sent out malicious emails disguised as if they were coming from European banks. Some researchers call the group Empire Monkey.
- A campaign by Fin7 group was discovered, which the group launched in the first half of 2018. It involved new tools, such as Astra panel and malicious programs called SQLRat and DNSbot. Apart from this campaign, the group started registering domains in May 2018 using the same pattern. Some of the domains have already been used, while others may be used in future attacks.
- Silence continued their attacks on the financial sector and successfully targeted IT Bank, a Russian bank, stealing 25 million roubles ($390,000). The group complemented their arsenal with a modified version of Ammyy Admin, HVNC, and a new malicious program for attacks on ATMs.
  We also discovered, that the hacking group sent GandCrab ransomware to South Korean targets. In general, the group seems to have shifted their focus to the Middle East and India.
- Lazarus group hacked into the network of Redbank, a Chilean company, and launched a campaign against South Korea called Operation Extreme Job. Group-IB specialists analysed a new RAT (RATv3.ps) used in the attacks on the financial sector in Southeast Asia. Along with these activities, Lazarus continued to attack cryptocurrency users.
- A new malware campaign was discovered earlier this year. The threat actors attacked POS terminals around the world aiming to steal bank card details. Their victims include financial, insurance, medical, and other organisations. FIN6 is believed to be behind the attacks.
- Winnti, a Chinese hacking group, resumed their attacks on the gaming industry, supposedly for financial gain.
- Unknown hackers carried out a large-scale campaign called Operation ShadowHammer, with more than one million potential victims around the word. The operation involved a massive compromise of Asus computers.
- In late March 2019, a theft was committed at a Kuwaiti bank, supposedly through SWIFT. The details of the attack have not been disclosed.

Financial threats

- A new malicious program for ATMs called HelloWorld was found. Additionally, there were reports about an alleged new Trojan called WinPot, which is in fact a popular ATM malware called Cutlet Maker v2 sold under a different name.
- Group-IB specialists researched new ATM malware believed to have been used by the criminal group Silence.
- Group-IB specialists discovered and studied 38 different JS Sniffer families that are used to infect websites and steal user payment information.
- Anubis, one of the most dangerous Android banking Trojans has been analysed. It is not sold publically on underground platforms and can only be purchased after messaging the seller personally. It is distributed through Google Play and uses Twitter to obtain its C&C servers. The number of targeted banks is very high.
- Andybot (aka Gustuff), an Android bot with an Automatic Transfer System (ATS)feature, has been active in Australia, the US and Europe. Its seller has been banned from the forum since December 2018. We believe that the bot will continue to be sold in more private circles.
- CometBot, an Android banking Trojan, was put up for sale.
- Red Alert, a malicious Android program for attacks on the world's banks, is still popular.
- Spam emails with RTM malware continued to be sent out in the CIS in the first quarter of the year. There were also mass emails with Troldesh ransomware and the malicious program Buhtrap.
- New Hidden VNC malware called BMW was put up for sale.
- Cetan Office Kit, a new macro generator for creating malicious documents, was detected.
- GlitchPOS, a new malicious program for POS terminals, was put up for sale.
- Flashpoint detected and studied DMSniff, a POS Trojan which has been used since 2016 in attacks around the world. Its specific characteristic is that is uses DGA.
- Information security researches reported a spike in the number of attacks with FrameworkPOS.
- The most active banking Trojan in Russia at the moment is Flexnet.
- The number of attacks using Asacub and Agent.BID Trojans markedly decreased.
- Trickbot was updated. The new version can collect remote desktop applications' account data. The malware is distributed through spam disguised as tax incentives for Deloitte. The spam emails contain an Excel document with a malicious macro which downloads and launches Trickbot on the victim's machine. The Trickbot attacks were detected in many countries, such as the UK, Australia, Spain, Italy, Germany, Canada, the US, the Netherlands and Austria.
- Gozi (aka ISFB/Ursnif/Dreambot), a banking Trojan, was detected in Australia, Japan, and Italy. Interestingly the Trojan had not targeted Italy before.
- BackSwap continued attacking Spanish banks.
- Gootkit was discovered in Canada, Germany, Italy, and Austria.
- Danabot, a new banking Trojan discovered in 2018, was detected in attacks on Polish banks at the beginning of 2019.
- IcedID was detected in the US, Canada and the UK.
- Ramnit was active in Japan.
- Baldr, a new data stealer, was put up for sale on underground forums. The stealer Arkei was made publically available.
- Group-IB specialists discovered another large database of Pakistani bank card dumps.
- Group-IB discovered bank card dumps, whose analysis revealed that the criminals apparently compromised the IT infrastructure of Datum Technologies, a US company that provides restaurant IT services. The database contains more than 2 million card dumps. We believe that the attack may have involved the new POS Trojans GlitchPOS or DMSniff.

Data leaks

- In February 2019, a criminal named Gnosticplayers started selling a large number of accounts (a total of over 840 million) stolen from hacked resources on Dream Market, an underground online shop.
- Customer data of the largest Indian bank State Bank of India (SBI) were stored on an unprotected server, it was discovered.
- In March 2019, the FBI reported that the company Citrix had been hacked. It appears that the criminals may have accessed and downloaded the company's business documentation.
- Verifications IO LLC, a marketing company has an unprotected MongoDB database with 150GB of personal data, it was found.
- The VoIP provider VOIPO created an unprotected database powered by ElasticSearch, with data on millions of calls for the last four years.

Threats to the government sector

Governments are always going to be under the threat of cyber espionage and in some cases suffer attacks on critical infrastructure. Group-IB specialists perform an independent analysis of such threats and are well-informed about the results of global expert studies. The following APT campaigns against government organisations were detected in Q1 2019:

- Cybercriminals from APT28 attacked a Kazakhstani industrial organisation in June 2018. Interestingly, common elements with the infrastructure of the BlackEnergy group were found. At the end of 2018, APT28 registered domains imitating CSIS systems (Center for Strategic and International Studies, US). In January 2019, the group carried out a campaign using an AutoIt-based malicious program called Zebrocy. In February, a sample of Seduploader was detected, which communicated with a C&C server used earlier. In March, a sample of Komplex was discovered. Its C&C domain was the one the group used back in 2016.
- Details on Cloud Hopper campaign attacks by APT10 were disclosed. In late 2017, the group attacked a U.S. law firm, in early 2018 — an international apparel company, and in late 2018 — a Norwegian company called Visma.
- A targeted attack on Los Angeles Times Olympic printing plant with Ryuk ransomware was detected.
- APT39 hacking group was discovered. Their goal is to steal personal information from telecommunications companies, with additional targeting of the travel industry, IT firms that support it, and the high-tech industry.
- The cybercriminal group Lazarus launched an attack on an Israeli security company exploiting a recently discovered WinRAR vulnerability.
- Kimsuky's new cyberespionage activities against South Korea were detected. These activities are part of their operations: Operation NK New Year, Operation Cobra Venom, Operation Fake Capsule, Operation Round Table, and Operation Low Kick.
- APT37 continued their attacks as part of the Rocketman campaign against South Korea.
- STOLEN PENCIL cybercriminals carry out an espionage campaign in the nuclear security sector.
- In Q1 2019, MuddyWater group continued their attacks on government entities, including the Belarusian Ministry of Defence and Ministry of Foreign Affairs. The group gained access to the

local network of Korek Telecom, a telecommunications company, and sent out further emails from legitimate users.

- OceanLotus criminals started using Kerrdown, a downloader malware family. In addition, they launched an attack on Vietnamese targets using the Cobalt Strike framework.
- Information emerged about potential web shells on different government websites, which are believed to belong to APT34.
- The recently discovered cybercriminal group APT-C-36 carried out attacks against Colombian government institutions, oil companies, and industry.
- Gaza Cybergang continued their cyberespionage activities against the MENA region.
- Unknown hackers carried out an attack on the Australian Parliament and gained access to the ruling Liberal and National coalition parties' network as well as the opposition Labor Party.
- The recently discovered Goldmouse group launched attacks against the Middle East using njRAT and a specially crafted Android Trojan.
- A new APT group called SandCat and the already well-known FruityArmor group exploit the zero-day vulnerability CVE-2019-0797 in their attacks.
- Chafer group launched an attack against foreign diplomatic entities in Iran using an updated version of the Remexi Trojan. Another detected attack carried out by the group targeted a Turkish government entity.
- Whitefly was behind the attack on Singapore's largest public health organization SingHealth, which had 1.5m patient records stolen, it was reported. The hackers also attacked the media, telecommunications companies and the engineering sector.
- Unknown hackers believed to be linked to Iran carried out a global DNS hijacking campaign.

Forecasts for Q2 2019

- Having gained the necessary experience to attack Russian banks, Silence group started to successfully apply their skills to attack international companies, actively preparing the infrastructure and testing new tools. The attack on an Indian bank is only the beginning of Silence's global expansion.
- The appearance of Cobalt imitators and the fact that they have already launched a successful attack leads us to believe that the group will continue their attacks in the future.
- Lazarus group will attack banks and cryptocurrency providers. Their main objective in the banking sector will be theft through SWIFT and attacks on ATMs.
- The successful attack on Metro Bank customers using a vulnerability in the SS7 protocol will hardly be the last one, until telecommunications companies around the world adopt and implement a new protocol for transferring confidential information. Until then, criminals will be able to listen to and intercept messages.
- Anubis, an Android banking Trojan, will be the biggest threat among mobile malware. There will also be attacks from the Android Trojans Red Alert and the new CometBot.
- The number of attacks on POS terminals will primarily rise in the US.
- Due to its low price and good functionality the new POS Trojan GlitchPOS may be used by criminals on a large scale. Other POS Trojans will also be used, resulting in millions of bank cards being compromised.
- We forecast increased activity of sniffers as one of the main methods to steal bank cards.

- Backswap, Trickbot, Gootkit, and IcedID will be the most dangerous banking Windows Trojans in Europe, the US and Canada.
- Gozi and Ramnit will remain the most dangerous banking Trojans in Japan.
- The new banking Trojan Danabot will expand its geography and in addition to Poland could start attacking other European countries.

Advanced threats in the financial sector

333

APT name	Regions attacked	Related notifications	Operation start
Cobalt	Global	CP-1438-66 – CP-1438-69	2016

In Q1 2019, the Cobalt group carried out several malicious email campaigns. All of the attacks, with the exception of the one on 30 January (where the final payload was not installed) involved a malicious program called Coblnt as the final payload:

- On 23 January 2019, Cobalt sent out emails from a mail server that belonged to the Indian bank Punjab & Sind Bank. The bank's infrastructure was allegedly compromised. The emails contained a link which downloaded a malicious document with a macro.
- On 30 January 2019, Cobalt carried out attacks on individuals well known in the financial sector. The emails were sent out from various mail servers and e-mail accounts under the name of an Interra Credit Union employee. Cobalt obtained the login-password pairs to access the email accounts from leaked databases. The email has a PDF attachment with a link to download the malicious file.
- On 27 February 2019, Cobalt sent emails to European banks. A document with a macro was detected. It was uploaded on VT from Romania and the UK. The document was only available at a specific address and might have been distributed via phishing emails with a malicious link.
- On 7 March 2019, Cobalt sent out emails from gmail.com accounts. The emails contained a link to download Payment Controls.doc, a macro-containing document.

Cobalt is a Russian-speaking cybercriminal group active since April 2016. Their attacks target the internal infrastructure of banks and organisations that have common infrastructure with banks (leasing and insurance companies) in Eastern Europe, the CIS, the Asia-Pacific region, and other regions. Their aim is to gain access to ATM, bank card, and interbank transfer management systems. To carry out their attacks, the group mostly uses phishing emails disguised as financial organisations and ATM manufacturers. The emails contain malicious attachments: a document with an exploit or a password-protected archive with an executable within.

APT name	Regions attacked	Related notifications	Operation start
Attacks imitating Cobalt (aka Empire Monkey)	France, Cyprus, Poland, Malta	CP-1864 CP-1865	2019

In February 2019, the Bank of Valetta (Malta) experienced an attack that by all indications was carried out by the Cobalt hacker group. However, during further investigation of this and other attacks on European banks, including ones carried out under the name of ING bank and Societe Generale, Group-IB concluded that these attacks had been launched by someone imitating Cobalt. Some researchers called the group Empire Monkey.

The similarities between these attacks and Cobalt's are the following. To ensure persistence the attackers used the Squiblydoo technique, which had earlier been used by Cobalt. They also had the same registry key names that Cobalt used. The main tool was the CobaltStrike framework. The domain names were very

similar to those previously used by Cobalt. The domain names in the attacks had been created using orangewebsite.com and purchased with Bitcoin, which is characteristic of Cobalt. Similar to Cobalt's latest attacks, the emails contained a link to download a document.

The infrastructure, however, is not Cobalt's. Their regular tools, such as JS Backdoor, were not used either. We conclude that the attacks were carried out by someone imitating Cobalt. The new attacks also used scripts created using Empire Framework.

APT name	Regions attacked	Operation start
Fin7	USA	January 2018

In March 2019, Flashpoint specialists discovered a campaign by Fin7 that had been carried out between May and July 2018 (there is a possibility that it started in January 2018). The specialists discovered that the group used an admin panel called Astra, which helped them quickly install scripts on targeted machines.

The criminals gained access to their victims' machines through phishing emails with malicious attachments. The emails are industry-specific and crafted to entice a victim to execute the attached document.

Some of the documents distributed the previously unseen SQLRat, a malware sample that drops files and executes SQL scripts on the host's system. SQLRat is designed to make a direct SQL connection to a Microsoft database controlled by the attackers and execute the content of various tables. The script retrieves an item from the bindata table and writes the file to disk. This file appears to primarily be a version of TinyMet—an open source Meterpreter stager—but the actors have the option to store and execute any binary loaded into the table.

The campaign also involved another payload called DNSbot, a backdoor that is used to exchange commands and push data to and from infected systems. DNS protocol is used to communicate with the server, but the malware is also capable of switching to encrypted channels, such as HTTPS and SSL.

Apart from this campaign, since at least May 2018 Fin7 has been registering domains with the same pattern (the same registration data, similar names *-cdn.com), which could have been used in their attacks. The specialists discovered a number of files that interacted with the registered domains, which means they can be associated with Fin7:

- On 14 February 2019, the file (MD5: 5ec2d6bb21903c9bebc184cab55d6a42), C&C: logitech-cdn[.]com was detected.
- On 2 March 2019, the file «Gilded.xlsb» (MD5: 1a3945b2385d6a45a80d7082923dd81b), C&C: tw32-cdn[.]com was uploaded to VirusTotal from the US.
- On 11 March 2019, the document MOD Fundraiser issues.xls (MD5: ac263c472afff1a455c39bcbe6435f96), C&C: cdn-skype[.]com was uploaded to VirusTotal.

All the files used a similar technique to download the malware. Upon opening the document the user is shown a page with the Windows Defender Antivirus logo for the first file and the DocuSign logo for the second and third files. The page shows recommendations that it says should be followed to be able to read the document: '1 Click on "Enable editing" to unlock the editing document downloaded from the internet. 2 Click on "Enable content" to perform Microsoft Word Decryption Core to start.'

After executing the macro, "wscript.exe" is dropped and launched as "mswmex.exe". The obfuscated version of JavaScript backdoor is stored in UserForm object, and is also written to querylog.txt in %LOCALAPPDATA%. The final execution of the backdoor is performed via this following command: "%USERS%\Contacts\mswmex.exe //E:jscript %LOCALAPPDATA%\querylog.txt".

As a result, the backdoor is downloaded with five functions in its code:

- main
- id (makes a WMI request to receive the MAC address and DNS hostname)
- crypt_controller (encodes/decodes the request)
- get_path (builds path URL based on pre-configured paths)
- send_data (sends data to the C&C server/requests commands from the C&C server)

Fin7 is a financially-motivated Russian-speaking criminal group that has been active since 2015. The threat actors use social engineering techniques and periodically update their attacking methods and tools trying to bypass detection mechanisms. Most of their attacks target hospitality and restaurant businesses in Europe and the US.

APT name	Regions attacked	Related notifications	Operation start
Silence	Global, Russia	CP-1645-11 – CP-1645-15	2016

In early January 2019, the cybercriminal group Silence carried out an attack in the English-language segment of the Internet. Silence.Downloader was uploaded to VirusTotal on 04 January 2019 from the US, Korea, and Ukraine. The file was signed with a valid signature of SEVA MEDICAL LTD, a UK medical company.

In mid-January 2019, Silence launched a spear-phishing campaign with a malicious attachment in the form of an invitation to the international financial forum iFin-2019. The emails were sent out under the name of Forum iFin-2019 from the mail server mail1.bankuco.com. The domain name had been seen in Silence attacks multiple times.

On 12 February 2019, media outlets reported that IT Bank experienced a theft. Group-IB specialists believe that the theft at IT Bank was committed by Silence, using a new malicious program for attacks on ATMs.

This suggestion is substantiated by several factors:

- There were recipients from @itbank.ru in Silence's January emails.
- The creation date of the new Trojan for ATMs is 10 February 2019.
- Debug information contains a string that points to IT bank (bkittest).
- Theft at IT Banks was reported on 12 February 2019.
- The theft occurred two days after the Trojan had been created.

In addition, the cybercriminals were exposed in other attacks, using modified Ammyy Admin and HVNC.

Moreover, in January 2019 Group-IB specialists researched the malicious program Proxy Bot, which had been uploaded to VirusTotal. They discovered the Indian bank IndusInd's network administrator account data, which had been compromised in an attack in August 2018.

In late February, Group-IB discovered Silence's new server, which is believed to have been configured with the aim to launch new malicious email campaigns. The attackers then started sending out emails in Korean under the name of the Bank of Korea with an archive containing Gandcrab ransomware.

APT name	Regions attacked	Operation start
Lazarus	Chile, Pakistan, Russia, South Korea, Global	December 2018

In January 2019, it was reported that at the end of December 2018 the cybercriminal group Lazarus hacked into the computer network of Redbanc, a company that services the infrastructure of all ATMs in Chile.

It is reported that the attack started from a post about a developer vacancy in a different company on LinkedIn, a social network, which a Redbanc employee responded to.

The person who apparently posted the vacancy then contacted the Redbanc employee to arrange a short interview, which was held in Spanish via Skype soon after.

After winning the candidate's trust, the threat actor offered them to install the program ApplicationPDF.exe on their computer under the pretense of creating an online-application form in PDF.

The installed software, however, was malicious and enabled the cybercriminals to scan data from within the company's network. It was discovered that the dropper's sample was linked to Lazarus's malicious program PowerRatankba, a variant of Ratankba malware based on PowerShell, which is used as a first-stage reconnaissance tool and to deploy next-stage implants on the targets that the criminals find interesting.

Similar malware was uploaded to VirusTotal from Pakistan, which leads to the conclusion that the country was among Lazarus's targets.

In mid-January 2019, Group-IB specialists obtained information about a malware sample that had been used in an attack on a South Asian bank.

The analysis established that the program is used as a main backdoor and can also be deployed as a second-stage backdoor after the Ratankba Trojan that Lazarus (aka HiddenCobra) use.

It was also found that the hackers used a new RAT in their attacks, which was distributed via compromised resources. The new RAT was dubbed RATv3.ps.

In late January 2019, Lazarus resumed their attacks on South Korea as part of their Operation Extreme Job campaign. The campaign's infection vector was a Microsoft Word document masqueraded as Cisco Korea job postings. It used legitimate content available as part of job postings on various sites.

CheckPoint specialists observed a malware campaign targeting Russian companies carried out by Lazarus cybercriminal group. All documents associated with this campaign were uploaded to VirusTotal from different sources in Russia during the week between 26 and 31 January 2019.

The main infection flow:

1. A ZIP file, which contains two documents: a benign decoy PDF document and a malicious Word document with macros.

2. The malicious macro downloads a VBS script from a Dropbox URL, followed by the VBS script execution.
3. The VBS script downloads a CAB file from the dropzone sever, extracts the embedded EXE file (backdoor) using Windows' "expand.exe" utility, and finally executes it.

In addition, Lazarus continued developing their attacks on cryptocurrency users. In July 2018, the hackers used malware versions that targeted both Windows and macOS machines. The cybercriminals continued their attacks on these systems. They developed custom PowerShell scripts that communicate with malicious C2 servers and execute commands from the operator. The C2 server script names are disguised as WordPress (popular blog engine) files as well as those of other popular open-source projects.

Lazarus (aka: Dark Seoul Gang, HIDDEN COBRA, Guardians of Peace) is a cybercriminal group that has been active since 2007. Specialists established that the members of this hacking group are from North Korea.

APT name	Regions attacked	Operation start
FIN6	India, Japan, USA	December 2018

In February 2019, Morphisec specialists reported a new malware campaign, in which the criminals attack POS terminals around the world to steal bank card details. The cybercriminals' victims have been financial, insurance, medical and other organisations in India, Japan, the US and other countries.

According to the research, one of their infiltration vectors is executed through HTA files, which execute PowerShell scripts as part of an embedded VBScript.

The POS malware samples used by the criminals to steal data differ. In some cases they use FrameworkPOS, while in others—PowerShell/WMI to load Cobalt Strike beacon with PowerShell extension directly into the memory. The Cobalt Strike beacon payload gives attackers full control over the infected system and the ability to move laterally to other systems, harvest user credentials, execute code and more.

The specialists believe that FIN6 is behind the attacks, since many indicators link to them: (WMI/PowerShell, FrameworkPOS, lateral movement and privilege escalation), with the difference of moving from Metasploit to Cobalt Strike).

FIN6 is a financially-motivated hacking group active since 2014. The criminals' victims are mostly casinos, hotels, retail chains, etc. Information security specialists believe that the hackers are based in Eastern Europe.

APT name	Regions attacked	Operation start
Winnti	India, Japan, USA, Russia	February 2019

ESET experts discovered new supply-chain attacks. Two games and one gaming platform application were compromised to include a backdoor. The attacks targeted Asia and the gaming industry. They were attributed to perpetrators called the Winnti Group.

Although the malware uses different configurations, the three affected software products included the same backdoor code and were launched using the same mechanism.

The payload code is started during the execution of the backdoored executable file.

Right after the PE entry point, the standard call to the C Runtime initialisation is hooked to launch the malicious payload before everything else.

The code added to the executable decrypts and launches the backdoor in-memory before resuming normal execution of the C Runtime initialisation code and all the subsequent code of the host application.

One of the second-stage payloads delivered to victims is Win64/Winnti.BN. The backdoor reports information about the machine such as the user name, computer name, Windows version and system language to the C&C server and awaits commands. The data is XOR encrypted with the key "*&b0i0rong2Y7un1" and base64-encoded. The data received from the C&C server is encrypted using the same key.

Recent versions of the malware include an auto-update mechanism.

Winnti's motives have not been identified at the moment. It is possible that the actors seek financial gain or plan to use a botnet as part of a larger espionage operation.

Winnti group (aka Axiom, APT17, BARIUM) has been observed since May 2012. The cybercriminals originate from China. The majority of victims detected to date have been in electronic gaming, multimedia, and Internet content industries, although occasional intrusions against technology companies have occurred.

APT name	Regions attacked	Operation start
ShadowHammer operation	Russia, Germany, France, Italy, USA, Spain, Poland, the UK, Switzerland, Portugal, Canada, Taiwan, Austria, Japan, Brazil, Global	June 2018

Kaspersky Lab reported a malware campaign dubbed Operation ShadowHammer. The incident can be described as a classic supply-chain attack: about half a year ago, criminals compromised Asus, managed to ensure persistence in their network, and started distributing backdoors through ASUS Live Update, an auto-update utility pre-installed on most Asus computers. It is used to automatically update certain components such as BIOS, UEFI, drivers and applications.

The attack took place between June and November 2018, affecting a large number of Asus users.

The experts believe more than a million users were affected worldwide.

The initial goal of the attackers was to target a small pool of users, which were identified by their network adapters' MAC addresses. To achieve this, the attackers hardcoded a list of MAC addresses in the trojanized samples and this list was used to identify the actual intended targets. With over 200 malicious samples analysed, the experts extracted more than 600 unique MAC addresses, whose hashes had been written into different versions of the utility.

The trojanized updaters were signed with legitimate certificates such as ASUSTeK Computer Inc. One of them expired in mid-2018. The attackers then switched to the second one, which as at late March 2019 has not been revoked.

Financial threats

Malware for Android

Threat name	Detection	Regions attacked	Related notifications
Anubis	2017	Global	CP-1847

Group-IB specialists studied samples of Anubis, a malicious program for Android, which was developed by a Russian-speaking virus writer with the nickname maza-in. The sale of the malware is not advertised on underground forums. Potential clients receive detailed information about the banking Trojan by contacting its author via personal messages on Exploit, an underground forum. When discussing the malware, users often note the developer's high professional skills and write that Anubis is the best Android Trojan on the market. Most of the time, maza-in asks the forum administration to delete these discussions not to attract attention. Anubis was first mentioned as early as 2017.

The banking Trojan is distributed via Google Play through light downloader apps which are not detected by antivirus solutions and are masqueraded as legitimate software. Upon installation, the malicious app downloads the actual payload – classified as Anubis – and installs it disguised as Flash Player or Google Play Protect.

The list of the targets – which are mostly banks – is quite extensive and includes many countries (you can access the full list in the related notification). There have been recent attacks on banks in Australia, the Netherlands, France, and Hong Kong.

The application has extensive functionality. If it is granted all necessary rights, it can intercept SMS messages, block incoming calls, show phishing windows (web fakes) to the user, obtain contacts from the contact list, execute USSD specified requests including redirecting calls to a different number through USSD, receive all incoming/outgoing/draft SMS messages and send them to the server, send SMS messages both to a specified number and to all numbers from the contact list, obtain the list of installed applications, encrypt data on the device (ransomware), intercept keystrokes (keylogger), deploy a SOCKS5 proxy (contained in a separate module), record audio and send it to the server, obtain current location data (through GPS/mobile network and Wi-Fi), show fake push notifications, launch any app installed on the device, and open URLs in browser.

If the C&C server with the necessary panel version has not been found in the existing list, the client will try to extract a new list of C&C servers through Twitter.

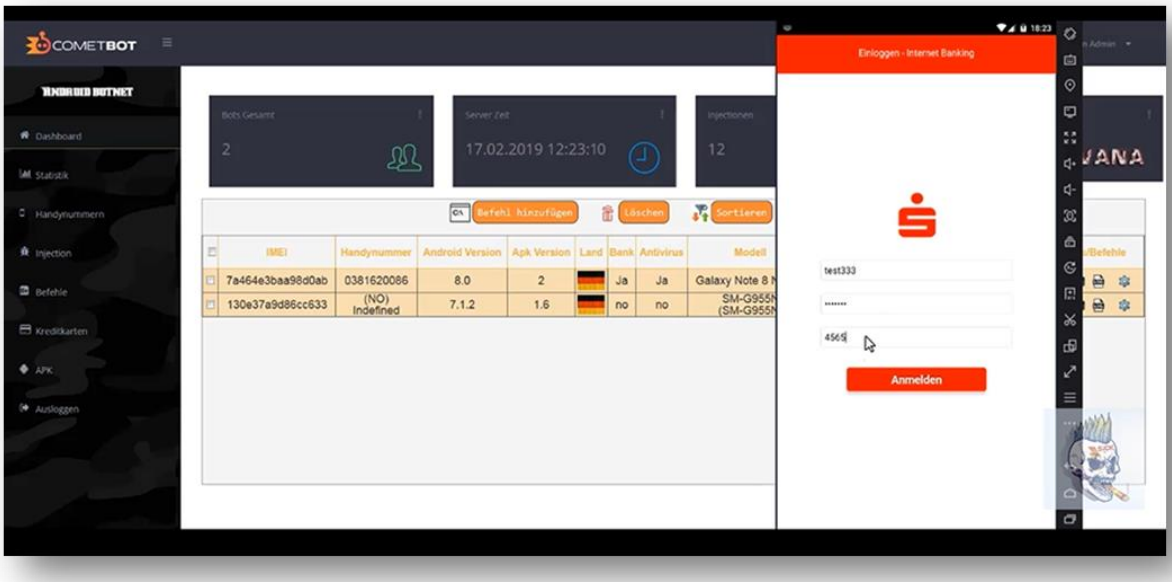
Threat name	Detection	Regions attacked	Related notifications
CometBot	February 2019	Global	CP-1869

On 18 February 2019, a Crime network forum user with the nickname SickHavana made a post about renting out new malware for Android called CometBot. It is based on the source code of the TucTuc Trojan, which had been made publically available earlier.

The Trojan's main functionality is:

- Intercepting and sending SMS messages.
- Sending USSD requests.
- SMS spam: spamming the infected device's contacts.
- Obtaining the contact list.
- Obtaining GPS coordinates.
- Checking whether the device is blocked.
- Web injections (web-fakes): banking applications, social networks and Google Store. The malware can obtain user authentication data, card details, and other sensitive information. Card data will be checked and transferred to the admin panel.
- Supporting additional domains (€10 per each new domain).

Features work on all Android OS versions (2 through 8).



CometBot admin panel screenshot

The author also published a list of German banks for which they had web fakes:
Comdirect
Commerzbank
Consorsbank
Deutsche Bank
DKB
ING DiBa
Postbank
Sparkasse
Volksbank
Santander

Threat name	Detection	Regions attacked
FlexNet	2014	Russia

The Trojan requests device administrative privileges. The request text is masqueraded as a Google Play agreement, which distracts the user and helps access the privileges.

On command from a C&C server, the application can do the following:

- change the C&C server's address
- send an SMS message to a specified number
- send bulk SMS messages with a specified text
- forward SMS messages to a remote server
- reply to SMS messages and delete them to conceal the fact from the user
- run USSD requests
- schedule commands: configuring a command template for new bots for a particular operator and country.

FlexNet also had phishing dialogs added to its functionality. They are disguised as popular applications in order to obtain the victim's bank card details. The following fake dialogue boxes were detected:
AliExpress
Alpha
Avito
Google Play
MyNewAlpha
telecard
VTB24
Sberbank
Uber

Threat name	Detection	Regions attacked
Red Alert	2017	Global

Red Alert is popular among buyers on underground resources. For a relatively low price, the customer gets functional malware with a big set of fake pages for attacks on banks in many countries, and cryptocurrency wallets. The author of the malware, a threat actor with the nickname Sochi, provides regular updates. The number of attacked companies rises. At the moment, the number of attacked banks and applications exceeds 200 targets, which are mainly banks, but there are also phishing dialogue boxes for mail clients, cryptocurrency applications, and various payment systems. Among the new features are web fakes for US and UK banks.

Threat name	Detection	Regions attacked
AndyBot aka Gustuff Bot	2017	Australia, USA, Europe

Gustuff has a unique feature which not been seen previously in malicious programs for Android—an ATS mechanism – on command it changes the values of fields in banking applications.

Other features are similar to other Android banking Trojans:

- displaying web fakes of banks
- sending SMS messages and USSD requests to the criminals' server
- launching a SOCKS server
- following links
- displaying push notifications
- sending information about the infected device to the C&C server
- transferring the victim's files, including photos, to the C&C server
- blocking the infected device
- detecting an installed antivirus
- resetting the device to factory settings

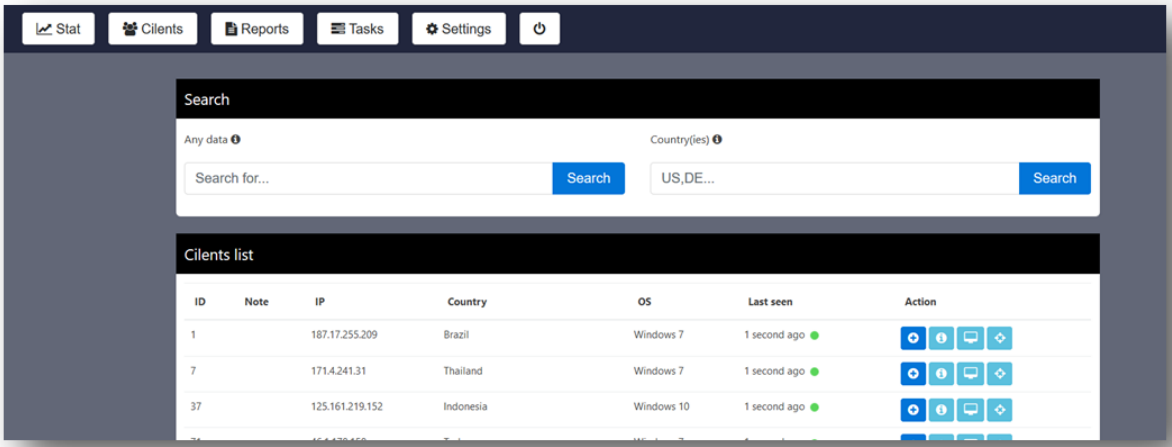
The seller of the malware, a threat actor with the nickname bestoffer, was banned on the forum in December 2018. We believe that the bot will still be sold, but in more private circles.

Malware and threats for PC

Threat name	Detection	Regions attacked	Related notifications
Hidden VNC "BMW"	December 2018	Global	CP-1848

Hidden VNC type malware called BMW was put up for sale on underground forums. Its developer is a criminal with the nickname BMWteame. The malware can remotely access the victim's machine and download other malicious programs. It works on Windows 7 to 10.

The malware is intended for remotely accessing an infected machine. One of HVNC BMW's specific characteristics is a loader function, which it uses to download other malware to the victim's device. The program can be run on Windows 7 and later.



Hidden VNC BMW admin panel screenshot

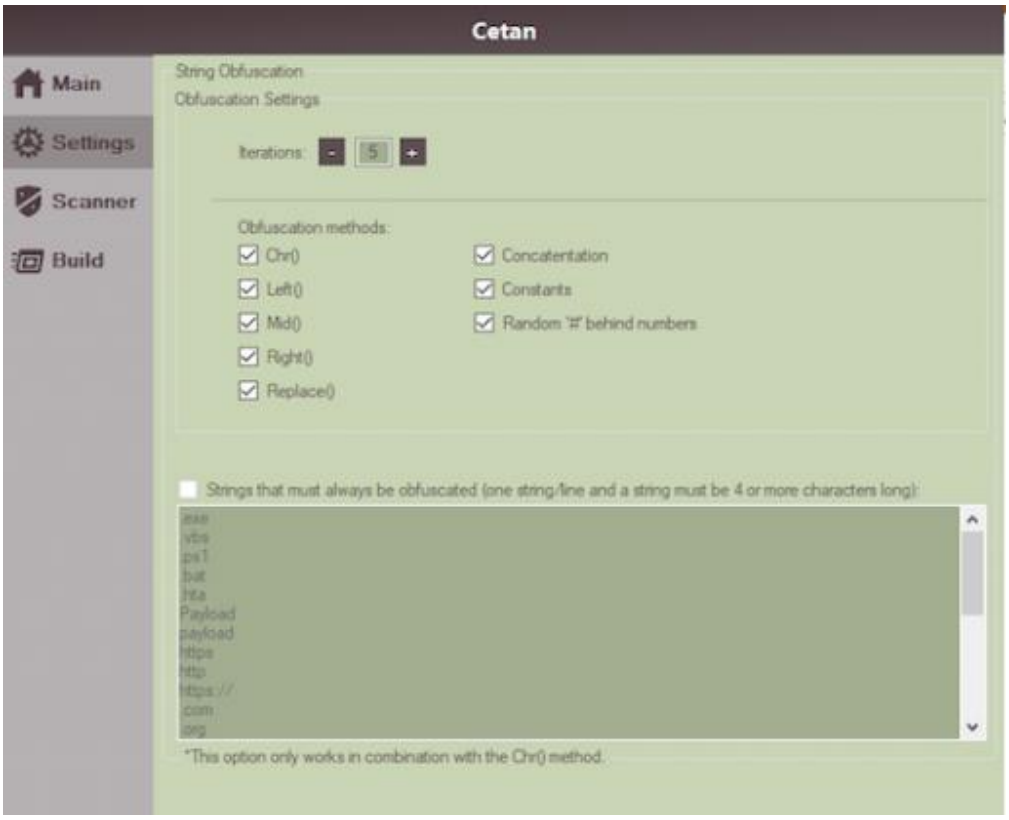
Threat name	Detection	Regions attacked	Related notifications
Cetan Office Kit	January 2019	Global	CP-1853

A user named cetan made a post on exploit.in, an underground forum, to sell a macro generator called Cetan Office Kit. Its main features are combined obfuscation algorithms and the ability to bypass 26 antiviruses.

According to the author, the generator is unique: it does not contain any code snippets from other similar programs and is written in C#. The software is intended for generating Office documents with a macro that executes the malicious code. The author claims that the generator does not use any code encryption methods, rather it uses various obfuscation algorithms to conceal the code. The malware has the following features:

- Generation of word (.doc) and excel (.xls), documents, which download and execute the .exe payload
- Unique obfuscation algorithms, and an option to choose the method and degree of obfuscation
- A built-in scanner that uses avcheck.net API;
- Social engineering settings (editing text and images).

Threat actors can use the generator to inject malware into target machines.



Cetan Office Kit screenshot (obfuscation settings window)

We should note, that in the second half of March, the seller was banned on the underground forum (they received the money from a buyer, but did not deliver the product). At the moment, public sales of the malware are suspended.

Threat name	Detection	Regions attacked	Related notifications
JS sniffers	2018	Global	CP-1844 – CP-1844-15

In the first quarter of 2019, Group-IB specialists detected a new family of credit card JavaScript sniffers called GMO. GMO is a type of malware intended for e-commerce websites that accept bank card payments. By injecting a malicious JavaScript code, criminals steal bank cards of users that purchase products on an infected site. The GMO sniffer was used to steal bank cards of FILA UK website users. It was later discovered that the same family was sniffers infected at least six other websites: jungleeny[.]com, forshaw[.]com, absolutenewyork[.]com, cajungrocer[.]com, getrxd[.]com, sharbor[.]com. The infected resources have more than 490,000 unique visitors per month overall.

GMO sniffers' main domain gmo[.]li used for the sniffer's JavaScript code storage and as a gate for stolen data collection was registered in May 2018. Each infected website hosted a simple JavaScript code that checked weather the user was on the payment page. To do that, the code searches for /checkout/ or similar paths in the browser address bar. If the check is successful, the code loads the main body of the sniffer through a link to the attackers' website. Each discovered sniffer version was intended for one website and contained a list of payment fields used on that website, depending on the payment gateway.

Group-IB discovered a total of 38 different families of JS Sniffers that were used to infect websites and steal user payment information. In 2019, Group-IB forecast a spike in the activity of JS Sniffers as one of the main methods of bank card theft.

Threat name	Detection	Regions attacked
Gootkit	2014	Canada, Germany, Italy, Austria

Gootkit is a banking Trojan that can record video, take screenshots, change web pages using web injects, redirect victims to phishing sites, install a keylogger, and block URLs.

Targets detected in Q1 2019:

Bank of Montreal
Scotiabank
Suntrust
Royal Bank of Canada
HSBC Bank
Fifth Third Bank (53 bank)
Caisses Desjardins
Citibank
Toronto-Dominion Bank (TD BANK)
ATB Financial
BB&T Bank
Deutsche Postbank AG
Bank of America
Beaubear Credit Union
Laurentian Bank of Canada
Blockchain.info
The Synovus Financial Corporation
The National Bank of Canada
Capital One
Chase Bank
Canadian Imperial Bank of Commerce (CIBC)
Commerzbank
Conexus Credit Union
Wells Fargo
Copperfin Credit Union
Ulster Bank
Banco Bilbao Vizcaya Argentaria (BBVA)
FirstMerit Bank
Intesa
TD Ameritrade
Sparkasse
JPMorgan Chase
Libro Credit Union
Lloyds Bank
Deutschen Bank
Regions Financial Corporation
Citizens Financial Group
PNCbank
Unionbank (US)
USAA Bank
Usbank
Bancamarche (it)
Bancagenerali (it)
Bancoposta
Hellobank (it)
Raiffeisen (at)
Bancapassadore (it)
Credit Agricole (it)
Unicredit (it)
Poste (it)
Allianzbank (it)

Threat name	Detection	Regions attacked
Trickbot	2016	The UK, Australia, Spain, Italy, Germany, Canada, USA, the Netherlands, Austria

Trickbot is a banking Trojan that uses techniques similar to those of Dyre. It is distributed by way of spamming. There were also cases when it was distributed using Emotet.

Trickbot samples detected in Q1 2019 target the following banks:

HSBC Bank
Commonwealth Bank of Australia
Oberbank (AT)
Scotiabank
Toronto-Dominion Bank (TD BANK)
HSBC Bank
Bank of Montreal
Fifth Third Bank (53 bank)
Royal Bank of Canada
ABN AMRO Bank
Caisses Desjardins
JPMorgan Chase
Usbank
Citibank
Bank of America
Australia and New Zealand Banking Group
Bancamarche (IT)
Bancacrasti (IT)
Caixa
Openbank (ES)
Barclays
BB&T Bank
Bankia (ES)
Bank of Scotland
Bendigo and Adelaide Bank
Deutsche Bank
Lloyds Bank
Deutsche Postbank AG
Sparda Bank
Westpac
Ulster Bank
Bank of Melbourne
Bank of South Australia (BankSA)
St.George Bank
Banco Bilbao Vizcaya Argentaria (BBVA)
ABANCA Corporación Bancaria, S.A.
Laurentian Bank of Canada
Blockchain.info
First Citizens Bank
Danske Bank
TSB Bank
Huntington Bancshares, Inc.
The National Bank of Canada
Capital One
Citizens Financial Group
Chase Bank
Canadian Imperial Bank of Commerce (CIBC)
Charles Schwab Corporation
Comdirect Bank AG
Commerzbank
Wells Fargo
Halifax
Bank of Queensland (BOQ)
Greater Bank
ME Bank
Teachers Mutual Bank (AU)
Hume Bank
Bankwest
Adelaide Bank
IMB Bank
Suncorp Bank
TD Ameritrade
KeyBank
Sparkasse
National Australia Bank
Regions Financial Corporation
Unicredit Bulbank (BG)
Suntrust
Macquarie Bank
Tesco Bank
PNCbank
USAA Bank

We should also note that in 2018 Trickbot started downloading IcedID, a Trojan which had previously been distributed mostly using the Emotet Trojan.

Threat name	Detection	Regions attacked
BackSwap	March 2018	Spain

BackSwap is a banking Trojan that uses unique methods to bypass antivirus solutions and steal bank customers' money. It was first detected (Q2 2018) in spam emails to users in Poland.

BackSwap uses a graphical user interface under Microsoft Windows and simulates key presses to avoid detection and bypass browser security. The hackers who developed BackSwap were detected in January 2018, when the group was still distributing its earlier malicious programs, for instance a program for stealing cryptocurrencies that replaced wallet addresses in the clipboard.

Unlike other banking Trojans, BackSwap does not inject the malicious code into browser processes since that would be easily detected by antiviruses. Instead, it uses Windows message loop events to know when the victim accesses the online bank and then injects the malicious code into the web page either via the browser developer console or into the address bar.

In Q1 2019, as well as at the end of 2018, BackSwap attacked Spanish banks.

Threat name	Detection	Regions attacked
Gozi (ISFB, Ursnif, Dreambot)	2007	Australia, Japan, Italy

In Q1 2018, we detected Gozi samples, attacking Australian and Japanese banks.

Attacked Australian banks:
Westpac
Suncorp
Bankofmelbourne
Banksa
Stgeorge
Commonwealth
Bendigobank
Bankwest
ANZ

Attacked Japanese banks:

Shinkin bank
The Bank of Tokyo-Mitsubishi UFJ
Aeon Bank
Credit Saison
Daishi bank
Hokkoku bank

Resona Bank
Tsukuba bank
Awa bank
Yamagata Bank
Japan Post Bank
Tsukuba Bank
Miyazaki Bank
Hiroshima Bank
Rakuten Bank
Idemitsu Credit Co.
Japan Net Bank

Fresh Gozi samples were detected that targeted Italy:

Cedacri
Poste
BNL
Bancaperta
Csebo
Inbank
Credem
Relaxbanking
Banca Monte dei Paschi di Siena (MPS)
Finecobank
Cedacri
Cbibanking
Bancapassadore
Friuladria
Intesasanpaolo
Unicredit
Bancagenerali
Deutsche Bank (IT)
Banca Popolare di Sondrio
Ubibanca
BPER Banca

Threat name	Detection	Regions attacked
IcedID (aka Bokbot)	2017	USA, Canada, the UK

It was first detected at the end of 2017. The malware can be used to steal financial information and launch targeted attacks. ICEDID is distributed mostly using Emotet but also through phishing emails with a malicious macro that downloads and launches ICEDID itself.

ICEDID has a modular architecture and functionality comparable to Zeus, including web injects, the ability to inject the code into other processes, and data theft. One of the bot's specific characteristics is the ability to deploy a proxy server on the infected machine and redirect the internet traffic using that server.

In addition to banks, ICEDID has lately attacked e-commerce businesses. In either case, the criminals' aim is to obtain bank card details: card number, CVV, expiration date, and the region where the victim is located.

The detected ICEDID samples target banks in the US, Canada, and the UK, as well as e-commerce vendors.

Threat name	Detection	Regions attacked
RTM	2015	Russia

The program is written in Delphi and is a modular Trojan. Judging by its functionality, the Trojan targets remote banking services and payment systems. Its latest tracked sample searched for the following remote banking services on the infected machine: BSS_PC, Faktura, HandyBank, QiwiCashier, Raiffeisen, RosBank, SberBank_BO, SberBank_Fiz, SberBank_PC, VTB24.
RTM group has a main panel and a separate Proxy panel containing banks, which they target specifically. All requests are sent to phishing servers where the traffic is proxied.
In Q1 2019, there was a high number of emails distributing the RTM Trojan. We detect such emails almost every day. The recipients are Russian-speaking legal entities. These are massive emails rather than targeted attacks.

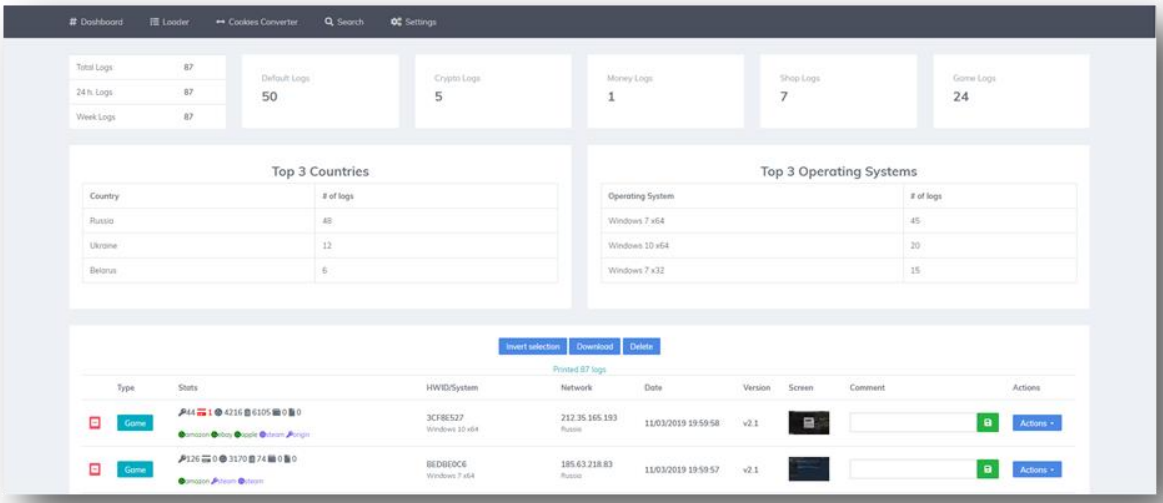
Threat name	Detection	Regions attacked
Danabot	2018	Poland

The modular banking Trojan Danabot was first detected in the spring of 2018. It uses web injects, intercepting the victim's data. It has VNC, Sniffer, Stealer, TOR, and RDPWrap modules.

The Q1 2019 samples attacked Polish banks.

Threat name	Detection	Regions attacked	Related notifications
Baldr Stealer	January 2019	Global	CP-1875

A new non-resident stealer called Baldr was put up for sale on underground forums. The malicious program can collect passwords and other information from browsers, cryptocurrency wallets, FTP clients, and other programs. Baldr also records data from messaging apps. The stealer has loader functionality, which enables it to download other malicious programs to infected devices.



Baldr Stealer admin panel screenshot

The malware was put up for sale in January. In March, the seller reported that they had over one hundred clients. This means that the stealer is highly popular due to a large number of posts (on many forums) and its low price (USD 150).

Threat name	Detection	Regions attacked	Related notifications
Arkei stealer	February 2019	Global	CP-1877

At the beginning of February, Arkei stealer was made publically available on an underground forum. Its developer with the nickname foxovsky said that they stopped supporting the stealer, which is why they made it publically available. The builder for the stealer was distributed through a Telegram bot for a short period of time. Then the bot stopped working.

Apart stealer features, Arkei also had loader functionality, such as downloading and launching files (possibly covertly) of any format upon download. After doing its job, the stealer destroyed all its working files.

At startup, Arkei is copied to the system directory, scans the OS for targeted browsers, and collects data from them. The stealer then collects files from the desktop of specified formats, puts all the collected data into an archive and sends it to the server along with a general summary of the system.

Threat name	Detection	Regions attacked
Ramnit	2010	Japan

The Ramnit banking Trojan was first discovered in 2010. In 2015, the Ramnit botnet was taken down by a joint international operation coordinated by Europol. The Trojan's activity, however, did not stop and it continued to be used to compromise bank cards in North America and Europe up until the beginning of 2018. It was followed by a lull, but in Q3 2018, we detected a botnet based on Ramnit, that is still active today. Among its targets are Japanese financial organisations:

Credit Saison
Idemitsu Credit Co.
Mitsubishi UFJ NICOS Co
Aeon Bank
Life Card Co.
Pocket Card Co.
Cedyna Financial Corporation
Epos Card Co.
Rakuten
Sumimoto Mitsui Card Co.

Threat name	Detection	Regions attacked	Related notifications
Compromise of Pakistani bank cards	February 2019	Pakistan	CP-1781-2

In the autumn of 2018, Group-IB specialists discovered credit card dumps affecting Pakistani banks' customers. The dumps were published on Joker's Stash, one of the largest underground hubs of stolen card data. In late January 2019, the same resource had two new sets of card dumps: the PAKISTAN-D + P-01 set with 1,535 entries and PAKISTAN-D+P-02 with 67,654 entries. All of the cards in the dumps belong to Pakistani banks.

Group-IB specialists believe that this event is part of a larger incident, which could potentially be linked to compromised Pakistani bank card systems.

Attacks on ATMs and POS terminals

Threat name	Detection	Regions attacked	Related notifications
HelloWorld ATM Trojan	January 2019	Global	CP-1845

On 11 January 2019, a user with the nickname gookee made a post on exploit.in, a forum, about selling new malware for Wincor/Diebold ATMs called HelloWorld. The program is sold as an executable file, an IMG image for saving it to a flash drive, a CD image, a floppy disk image and an ISO image. The program is a modification of the well-known Cutlet Maker Trojan.

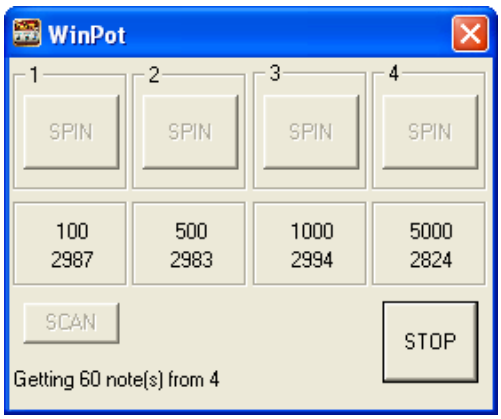
It differs from Cutlet Maker in that it:

- does not need a keyboard to dispense money
- removes its traces
- takes up 60kB

Threat name	Detection	Regions attacked	Related notifications
Cutlet Maker v2 (aka WinPot)	May 2018	Global	CP-1592-2

At the end of 2018, new ATM malware called WinPot was put up for sale on underground resources. Group-IB specialists contacted the seller (nicknamed wav) to obtain new information. They learnt that WinPot and Cutlet Maker v2 is the same malware under different names.

Interestingly, Cutlet Maker v2 was put up for sale as early as May 2018. We should note that Cutlet Maker v2's functionality is almost identical to that of Cutlet Maker. The new Trojan differs from its predecessor in that there is no need to generate activation passwords.



Cutlet Maker v2" (aka WinPot) interface screenshot

Threat name	Detection	Regions attacked	Related notifications
xfsasdf.txt (a Trojan believed to have been developed by Silence)	February 2019	Global	CP-1645-14

On 25 February 2019, a malicious program for attacks on ATMs was uploaded to VirusTotal from Russia through the web interface. Group-IB specialists analysed the program and established that it is intended for dispensing cash from ATM cassettes.

In addition, the analysis prompted suggestions that the malicious program was used by Silence group in their attack on the Russian bank IT Bank in February 2019. There is a number of indicators pointing to that: similar timeline and artifacts in the debug information.

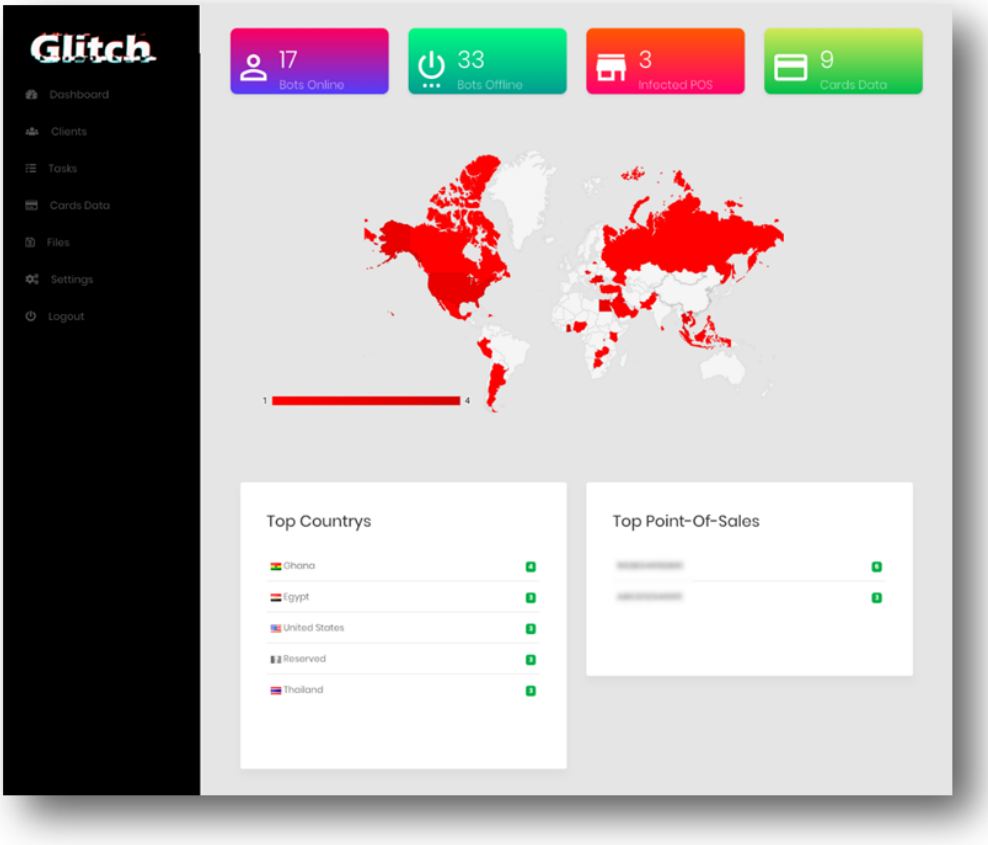
The suggestion is substantiated by the following factors:

- There were recipients from @itbank.ru in Silence's January emails.
- Creation date of the new ATM Trojan is 10 February 2019.
- Debug information contains a string that points to IT bank (bkittest).
- The theft at IT Bank was reported on 12 February 2019.
- The theft occurred two days after the Trojan had been created.

The program is very different from the Atmosphere Trojan, which Silence developed earlier.

Threat name	Detection	Regions attacked	Related notifications
GlitchPOS	February 2019	Global	CP-1874

GlitchPOS, a new malicious program for POS terminals was put up for sale. Glitch POS can compromise bank card data (Track 1 and Track 2). The program has loader functionality, which allows it to download other malware. Glitch works on OS Windows from XP to 10.



GlitchPOS admin panel screenshot

The author of the malicious program, a threat actor with the nickname edbitss, says that the program can bypass antiviruses and sandboxes. All these advantages and the program's low price (USD 250 for the built program and USD 600 for the builder) can prompt its widespread use.

Threat name	Detection	Regions attacked
DMSniff	2016	Global

Flashpoint reported about DMSniff, a malicious program for POS terminals that has attacked small and medium-sized businesses (primarily restaurants, cinemas, and other entertainment and hospitality businesses) since 2016. The program uses DGA to communicate with its C&C servers. It was discovered, that the criminals do not target any specific region or country, since the infections have been recorded worldwide.

Threat name	Detection	Regions attacked
FrameworkPOS	2016	Global

Morphisec security researches reported about a new malware campaign, in which the criminals attack POS terminals around the world in order to steal bank card data. The cybercriminals' victims have been financial, insurance, medical and other organisations in India, Japan, the US and other countries.

The researches link the attacks to the FIN6 group or Cobalt imitators.

One of their attack vectors is executed through HTA files (HTML Application), which execute PowerShell scripts as part of an embedded VBScript.

The attackers use FrameworkPOS, a malicious program that has been known since 2016.

Threat name	Detection	Regions attacked	Related notifications
Bank card compromise in restaurant businesses	February 2019	USA	CP-1875

Group-IB discovered a new set of bank card dumps on Joker's Stash, an underground hub of stolen bank card data. The analysis showed that the criminals may have compromised the IT infrastructure of Datum Technologies, a US company that provides restaurant IT services. The database contains more than 2 million card dumps.

Datum Technologies is the IT vendor for restaurant chains, such as Buca di Beppo Italian Restaurant, Earl of Sandwich и Planet Hollywood.

The number of cards, the sale of magnetic stripe data (the dumps) without PIN codes, and the fact that the cards' breakdown by banks is relatively even, suggests that the source of the compromise was a network of trojanised POS terminals. We believe the attack was carried out in the following way: the criminals compromised Datum Technologies's network and — having access to it — were able to infect outlets with POS terminals with the malware, which intercepts magnetic stripe data from the infected devices' RAM. Some of the cards may have been cashed out by the criminal group, while others may have been sold to Joker's Stash, a card shop. We believe that the attack may have involved the Glitch POS and DMSniff Trojans, which appeared very recently.

Pro-government APTs

APT name	Regions attacked	Operation start
APT28	Kazakhstan, Belarus, USA	June 2018

In January 2019, it was reported that APT28 group attacked a Kazakhstani industrial organization in late June 2018. The attack was carried out through phishing emails with the attachment "(28.06.18) Izmeneniya v prikaz PK.doc" under the name of the Ministry of Energy of Kazakhstan. Upon opening the document, the user is offered to "enable content". As a result, Zebrocy, a malicious program, is dropped on the machine. For the C&C server the group used an IP address (193.23.181[.]151) that had been used by BlackEnergy group to attack the same organisation a week earlier. There was another IP address discovered, that was used jointly by APT28 and BlackEnergy (185.217.0[.]124).

According to Microsoft, on 6 December 2018 APT28 registered several domains that imitated CSIS systems (Center for Strategic and International Studies, US). They may have been used to set up fake authorisation pages or to send emails to the organisation's employees in an effort to trick them into revealing their passwords. The information about whether the attack with these domains was actually carried out has not been disclosed.

In January 2019, a new campaign by APT28 was discovered. The initial infection vector has not been identified, but we should note, that the group often used decoys with a malicious macro. The detected sample was the Zebrocy loader packed using UPX v3.0 and written in AutoIt. After decompiling it, the specialists noted that the script was quite simple: it was not obfuscated and did not have the functionality to bypass analysis mechanisms. Parameters, such as C&C, URL, and payload path are set up statistically. First, the program extracts information about the victim's machine and takes screenshots with an interval of one minute. The collected information is sent to the C&C server via HTTPS after adding random symbols to the message in order to hinder analysis. After establishing connection with the C&C server, the attackers analyse the collected information and, if the victim is interesting to them, send the final payload to the infected machine. The C&C server was not accessible during the analysis, which is why it was not possible to identify the malicious program used as the final payload. On 25 January 2019, one of the researches noticed that APT28 was sending out emails impersonating a Tajikistan embassy from the email address tajembassy@bk.ru. At least one of the recipients was the Belarusian Ministry of Defence. The email had an .arj archive attachment, which contained a decoy document titled Gazette of Minister, state Minister of 2019 (2).pdf with the Zebrocy AutoIt.

On 20 December 2018, a file titled UDS 2019 Current Agenda.doc was detected, a possible reference to the Underwater Defence & Security 2019 event. The document was used as a decoy by APT28 in their attack. Its content may have been taken from the official website of the event. The document contains a malicious macro and a base64-encoded string, from which it extracts Seduploader. After executing the macro, two files are created: %TEMP%\clnb.dat and %ALLUSERSPROFILE%\adobe.dll. The attackers use WMI to launch clnb.dat and add RegKey *HKCU\Software\Microsoft\Windows\CurrentVersion\Run\AdobeAcrobat* with the REG_SZ value %ALLUSERSPROFILE%\adobe.dll to ensure persistence. As a result, the payload Seduploader is dropped on the victim's machine. On 13 February 2019, another Seduploader sample (adobe.dll) was uploaded to VirusTotal from the US. The file may have been used by APT28 as part of their current campaign. The C&C server was the same domain as the one in the previous file.

On 16 March 2019, a malicious program called Komplex was uploaded to VirusTotal. It is identical to the Komplex sample APT28 used as part of their attack on the aerospace industry in 2016. We should note, that both samples use the same C&C server appleupdate[.]org.

APT28 (also known as Fancy Bear, Sednit group, Sofacy, Pawn Storm, Strontium, Tsar Team, TG-4127, Group-4127, TAG_0700, Swallowtail, Iron Twilight, and Group 74) has been active since 2004. Its members are Russian speakers. Most of their attacks have targeted political and military organisations, and to a lesser extent media outlets and sports organisations.

APT name	Regions attacked	Operations start
APT10	Norway, USA	2016

In February 2019, information about attacks by APT10 emerged: in late 2017 they attacked a U.S. law firm, in early 2018 — an international apparel company, and in late 2018 — Visma, a Norwegian company. All of these attacks were carried out as part of the Cloud Hopper campaign, which started in 2016.

In late 2017, APT10 group attacked a U.S. law firm. The attackers first gained access to the victim's network through Citrix servers. Once inside the network, the attackers deployed their own customized malware and used known good binaries that have DLL search order hijacking issues in order to perform DLL sideloading to execute customized versions of Mimikatz. The attackers moved laterally in the network, mounted the remote drive on a system, copied the file 1.bat to it, and used task scheduler to execute and then delete it. The attackers archived the compromised data and sent it to Dropbox. In addition, server-side China Chopper webshell was deployed. The attackers also used TeamViewer. APT10 took the same steps in early 2018 in their attack on an international apparel company.

On 17 August 2018, APT10 gained initial access to the Norwegian company Visma through two hacked Citrix infrastructure accounts. The attackers then scanned the victim network and deployed malware tools. The theft of the organisation's login credentials was conducted within two and a half weeks after initial access.

On August 30 2018, APT10 deployed a modified version of Trochilus that had its C2 communications encrypted using Salsa20 and RC4. The attackers used the DLL sideloading technique to load the payload.

On 4 September 2018, a second infection chain took place with the deployment of Trochilus. It was almost identical to the 30 August 2018 attack.

Specialists established that the DLL sideloading technique was also used to deploy Mimikatz, a tool for user credential theft. By using the newly acquired credentials, the attackers accessed Visma's Microsoft Active Directory domain controller, deployed Trochilus, and made a copy of the "NTDS.DIT" database file containing Active Directory data for Visma's corporate network, including password hashes for all users in the domain. The NTDS.DIT file and accompanying stolen data was then packaged up following a naming convention of a short run of repeating characters (for example, kkk.rar, ss.rar, gggg.rar, etc) and uploaded to Dropbox.

APT10 is a Chinese cybercriminal group active since at least December 2009. According to some researches, the group has been active since 2006. The group carries out attacks to primarily spy on construction, engineering, aerospace, telecommunications, and government organisations. The most

targeted organisations are in Japan. Other victims include organisations in India, South Africa, South Korea, Sweden, USA, Canada, Australia, France, Finland, the UK, Brazil, Thailand, Switzerland, and Norway.

APT name	Regions attacked	Operations start
Targeted attack on Los Angeles Times Olympic printing plant, using Ryuk ransomware	USA	December 2018

At the end of 2018, Los Angeles Times Olympic printing plant was infected with ransomware, Tribune Publishing reports. The attack disrupted the printing and delivery of publications that depend on the plant, such as the Los Angeles Times, New York Times, Wall Street Journal, Chicago Tribune, Post-Tribune, Capital Gazette, Baltimore Sun, Hartford Courant, Carroll County Times, and Lake County News-Sun.

The malware behind the attack appears to be Ryuk ransomware, since the corrupted files have the .ryk extension.

Ransomware known as Ryuk was discovered in early August 2018. In two weeks, Ryuk attacked various organisations around the world. The campaign targeted several enterprises, encrypting hundreds of personal computers, storage and data centres in each infected organisation.

Unlike common ransomware, systematically distributed via spam campaigns and exploit kits, Ryuk is used exclusively for tailored attacks.

In fact, its encryption scheme is intentionally built for small-scale operations, so that only crucial assets and resources are infected in each targeted network with its infection and distribution carried out manually by the attackers.

It was established, that the file structure is visibly identical to the one used in HERMES, down to the distinctive 'HERMES' marker, which the malware uses to identify files which it has already encrypted.

The HERMES ransomware first gained publicity in October 2017 when it was used as part of a targeted attack against the Far Eastern International Bank (FEIB) in Taiwan.

In that attack, commonly attributed to the North Korean group Lazarus, a hefty $60 million was stolen in a sophisticated SWIFT attack. In this case, it seems the HERMES ransomware was delivered to the bank network for sabotage purposes. Ryuk, however, is used as the main attack tool.

It was established that Hermes 2.1 was sold on a Russian underground forum in October 2017. The author and seller of Hermes 2.1 emphasises that he is selling a kit rather than a service. This suggests that a buyer of the kit must do some fine-tuning by setting up a distribution method (for example, spam, exploit kit, or RDP) and infrastructure to make Hermes work effectively. It is possible that by making these adjustments, the attackers created Ryuk, an altered version of Hermes 2.1.

Crowdstrike specialists attribute the attacks on the printing plant to a hacking group called Grim Spider. According to the experts' report, Grim Spider is a cell of Wizard Spider, a larger cybercriminal organisation

that created the famous banking Trojan TrickBot. Crowdstrike, Kryptos Logic and FireEye said that many affected computers had been infected with TrickBot, before Ryuk.

APT name	Regions attacked	Operation start
APT39	Qatar, Saudi Arabia, Egypt, Turkey, UAE	November 2014

In December 2018, FireEye specialists discovered a new cyber espionage group called APT39, which engages in personal information theft. The hackers may be linked to Iran.

APT39 likely focuses on personal information to support monitoring, tracking, or surveillance operations that serve Iran's national priorities, or potentially to create additional accesses and vectors to facilitate future campaigns.

APT39 primarily leverages the SEAWEED and CACHEMONEY backdoors along with a specific variant of the POWBAT backdoor. While APT39's targeting scope is global, its activities are concentrated in the Middle East. APT39 has prioritized the telecommunications sector, with additional targeting of the travel industry and IT firms that support it and the high-tech industry.

While its victims are located in different countries around the world, APT39 has special interest in targets in the Middle East, in particular in Qatar, Saudi Arabia, Egypt, Turkey, and the UAE.

APT name	Regions attacked	Operation start
Lazarus	Israel	March 2019

The cybercriminal group Lazarus launched an attack on an Israeli security company, Haaretz newspaper reports.

According to ClearSky, the hackers' objective was either industrial or military cyber espionage. The operation was exposed at the beginning of March after one of the security company's employees received an email in broken Hebrew disguised to look like it was from his colleague.

The researchers implicated Lazarus Group based on digital evidence including a malicious implant known as Rising Sun that had been attributed to the group. The researchers, however, did not rule out a false flag operation posing as Lazarus.

The suspected Lazarus operatives looked to leverage a vulnerability in WinRAR file-archiving software that was disclosed in February 2019. The vulnerability itself lies in unacev2.dll, a library used to parse ACE archives. An attacker can craft an ACE archive that, when opened exploits a path traversal flaw to trick the archiving tool into extracting the files into a path of the attacker's choosing. For example, an attacker can make the malicious file extract into the startup directory to launch it automatically on every startup.

Lazarus (also known as Dark Seoul Gang, HIDDEN COBRA, Guardians of Peace) is a cybercriminal group that has been active since 2007. Specialists have established that the members of the group are from North Korea.

APT name	Regions attacked	Operations start
Kimsuky	South Korea	October 2018

In January 2018, a new wave of attacks by the cybercriminal group Kimsuky was detected. We should note, that the group does not slow down and continues their attacks on South Korea.

The operations the hackers have carried out have been dubbed Operation NK New Year, Operation Cobra Venom, Operation Fake Capsule, Operation Round Table, and Operation Low Kick.

The first wave was detected on 3 January 2019 with the document "190101-신년사_평가.hwp". The title of the document used by the malicious code contains the phrase “New Year assessment for North Korea in 2019”. Its content looks similar to government documents.

The main host file is written in the EXE format and contains three SRV resources. Each resource contains a malicious code in the form of 32-bit and 64-bit malicious programs and is disguised as HncChecker.dll.

Depending on the Windows version, each DLL module is created and works differently. The malware also logs and stores keystrokes. The information collected on an infected computer is then sent to the hackers via a special email service in Korea.

On 7 January, Kimsuky carried out a large-scale phishing campaign. 77 media reporters from the South Korean Ministry of Unification received an email titled TF reference info. The attacks involved Windows Script Files (.wsf). The hackers made sure to remove all their traces. The .wsf file tries to connect to a particular Google Drive using malicious commands.

At the end of January, the malicious files were masqueraded as ALYac security module by East Security. Security specialists note, that these attacks were also carried out against the South Korean Unification Ministry reporters.

On 21 February 2019, the hackers launched a new wave of attacks. The attack vector is believed to be phishing. A malicious HWP file was attached to an email and sent to the victim.

The attack referred to a Trump-Kim Jong Un meeting and as a decoy used a document with information about the second U.S.-North Korea summit planned for 27-28 February 2019 in Hanoi, Vietnam.

On March 20, 2019, a website for studying the policies of public and private institutions in Korea and the homepage of a specific academic group studying the unification of North and South Korea were hacked in multiple contexts. The circumstance of trying to spread malicious code stealthily were identified.

Kimsuky (also known as Velvet Chollima) is a hacking group that is believed to be based in South Korea. The group has been active in attacking entities on the South Korean territory since 2010.

APT name	Regions attacked	Operation start
APT37	South Korea	October 2018

On 18 January 2019, East Security Cyber Threat Intelligence specialists observed a new development of the Rocketman campaign by APT37 hackers. The attack involved an MS Office XLS vulnerability instead of an HWP document vulnerability.

The author of the malicious document is mentioned as RKS, while the person who was the last one to make changes to it has the 'HighExpert' ID.

The file «홍삼6품단가.xlsx» contained a price list for a unit of product. At the bottom of the document the victim was asked to press [Use content].

When the malicious code is activated, it activates an external link code included in the XLS, followed by a PoweShell Import module command to access a Korean medical website to download and execute the malicious files.

The file created in the temporary folder path, is disguised as a shortcut for a Korean security program.

The attackers get additional commands through the website PubNub to delete files and folders. PubNub is a global Data Stream Network and real-time infrastructure-as-a-service company.

If the attacker obtains administrative privileges and executes the erase command, the MBR sector of all disks will be deleted.

APT37 (also known as Group123, Reaper, ScarCruft, Geumseong121, Red Eyes) is a North Korean cyber espionage group active since about 2012. The group primarily targets South Korea, but also Japan, Vietnam, Russia, Nepal, India, Romania, Kuwait, and other regions.

APT name	Regions attacked	Operation start
STOLEN PENCIL	USA	Ноябрь 2018

In February 2019, Palo Alto Networks researchers identified phishing emails sent in November 2018 containing new malware.

The phishing emails were designed to appear as though they were sent from a nuclear security expert who currently works as a consultant in the U.S. The emails were sent using a public email address with the expert's name and had a subject referencing North Korea's nuclear issues. The emails had a malicious Excel macro document attached, which when executed led to a new Microsoft Visual Basic (VB) script-based malware family dubbed BabyShark.

The malware is launched by executing the first stage HTA from a remote location, thus it can be delivered via different file types including PE files and malicious documents. It exfiltrates system information to the C2 server, maintains persistence in the system, and waits for further instructions from the operator.

The experts detected phishing emails targeting:

- A university in the U.S. which was to hold a conference on North Korean denuclearization
- A research institute based in the U.S. which serves as a think tank for national security issues, and where the previously referenced nuclear expert currently works

The analysis of BabyShark suggested that STOLEN PENCIL could be behind the attacks.

STOLEN PENCIL is a cyber-espionage group first detected in May 2018. The hacker's activity is linked to North Korea.

APT name	Regions attacked	Operation start
MuddyWater	Belarus, Iraq, Iran	January 2019

On 3 January 2019, a document with malicious content was detected. It installed the POWERSTATS backdoor into the system. The emails were intended for the Belarusian Ministry of Defence and Ministry of Foreign Affairs. The address in the email and the domain of the sender belong to Vlasova Mikhel & Partners, a legitimate law firm in Belarus. The email intended for the Belarusian Ministry of Defence was sent from an address that belonged to a Belarusian National Technical University employee. The email contained a malicious attachment, which downloaded the payload — the POWERSTATS backdoor.

On 17 January 2019, the attackers sent out different documents with government-related titles.

On 13 February 2019, another document was detected, which the attackers used to gain access to the local network of Korek Telecom. The decoy document contained a blurred logo of the company on its first page and asked the victim to enable macros to display the content. Upon enabling the macros, the device was infected with the POWERSTATS backdoor.

A month later, a document titled Missan dashboard.doc was detected. According to the subject of the email, it was sent from Shaker Abdalkareem (shaker.Abdalkareem@korektel.com) to Dalal Khalid (Dalal.Khalid@korektel.com) and to a group of other recipients who were copied in the email to increase the probability of infection. The email was sent out via local communication channels, which suggests that the attackers had been able to gain access to a legitimate account. Judging by the name of the decoy document, the email focused on Missan Oil Company related issues. Missan Oil Company is a state-owned oil and gas company in the city of Maysan, Iraq, and may be Korek Telecom's customer.

Since 16 March 2019, three decoy documents that deliver the POWERSTATS backdoor have been uploaded to VirusTotal.

The detected documents were created by a Windows user with the nickname Gladiyator_CRK. The nickname belongs to a real person named Nima Nikjoo, a network security researcher who in their Twitter account said that they researched the activity of MuddyWater hackers.

One of the decoy documents has a blurred coat of arms of Iraqi Kurdistan where the city of Erbil is located. The mobile operator Korek, one of the victims of previous attacks, is based in that city.

It is alleged that in December 2018 MuddyWater uploaded a PoC exploit to YouTube. The exploit detects Kaspersky Lab Anti-Virus. This was done after a news story was published on securelist.com, in which Kaspersky Lab did not take MuddyWater's activities seriously enough. The suggestion is based on MuddyWater's comment on the news story.

MuddyWater is a hacker group that has been active since 2017 mostly in the Middle East. The group uses their own backdoors based on PowerShell called POWERSTATS. The group's main activity is cyber espionage pursuing Iran's interests.

APT name	Regions attacked	Operation start
APT32	The Philippines, China, Vietnam, Cambodia	March 2018

Palo Alto Networks' research revealed that in March 2018 OceanLotus group started using a new downloader, which the specialists called KerrDown. The downloader delivered Word documents with a malicious macro and RAR archives, using the DLL Side-loading technique.

One of the documents contains a text in Vietnamese and two tables on the first page with Base64-encoded text with the font size changed to 1. The macro, which is activated by the user, checks the bitness of the running system and based on that information chooses which table to decode the payload from.

After decoding, a PE file is dropped. It receives the DES-encrypted payload from a remote location and executes it into the memory. This means that only the downloader is left in the system. The URL of the remote node varies depending on the system's bit count. The downloaded payload is Cobalt Strike Beacon.

Some of the malicious files exploited the CVE-2017-0199 vulnerability.

According to ESET, OceanLotus started reusing their technique to distribute self-extracting (SFX) archives in mid-January 2019.

One of these SFX archives is crafted in such a way that the description of the file states it is a JPEG image.

The SFX script invokes the dropped file twice. The first time it is called, the file sets a registry value to decode the DLL file. The second time it is called, it reads the same value and loads it into memory. In turn, the DLL retrieves the content of its resource and decrypts it using AES-256-CBC. Depending on the privilege level, the binary data will be written either to

"%appdata%\Intel\logs\BackgroundUploadTask.cpl" or
to "%windir%\System32\BackgroundUploadTask.cpl". The CPL file is a DLL, which exports a CPlApplet function. This file decrypts and executes the backdoor. The researchers observed changes in the backdoor's configuration from sample to sample. The authors started removing names from additional DLL libraries and then stopped packaging the third DLL file, choosing to embed just one.

The researchers also observed documents exploiting the CVE-2017-11882 vulnerability. One of them was FW Report on demonstration of former CNRP in Republic of Korea.doc, which targeted Cambodian politicians. The attack involved a DLL Side-Loading technique.

On 6 March 2019, the company Volexity presented their report on OceanLotus at RSA Conference 2019. According to the report, in 2019 the group started using a new framework for tracking and profiling Matomo users.

The researchers suggested that some of the compromised websites were actually launched and run by OceanLotus. Others were doppelganger domains that mirrored content from legitimate websites. It should be noted, that apart from the profiling code, the doppelganger websites contained keyloggers. The researchers also observed Facebook blogs that they believe are run by OceanLotus.

The end of Q1 saw a campaign that involved phishing emails with malicious attachments. The emails mentioned various invitations and CVs.

One of these invitations was delivered in a RAR archive. It contains a legitimate Microsoft file called WinWord.exe, which is renamed in way as to make the user think it is a Word document and launch it. The archive also contains the malicious library wwlib.dll. This way the attackers use the DLL Side-loading technique. This time the name of the file contains NHNN, an abbreviation that points to the State Bank of Vietnam.

OceanLotus, also known as APT32/APT-C-00/SeaLotus/Sinh Tử Lệnh/Cobalt Kitty, has been active since late 2009 and is believed to be based in Vietnam. The group attacked Vietnamese bloggers and dissidents, and launched targeted attacks on government and industrial entities in Vietnam, Cambodia, China, Laos, the Philippines, Germany, and the US. Along with phishing emails to potential victims, OceanLotus carries out watering hole attacks.

APT name	Regions attacked	Operation start
APT34	China, Saudi Arabia, Turkey, Israel, Zimbabwe, Oman, Kazakhstan, Qatar, Cambodia, North Korea, Columbia, Kuwait, Lebanon, Macau, and Egypt	2018

On 19 March 2019, a malware researcher published a screenshot of a message they had received in Telegram from a user named Mr_L4nnist3r.

The message was the following: “I have access to top secret information and hacking tools of Iran ministry of intelligence and security ("vezarat etelaat") from OILRIG campaign / APT34.”

The message was sent along with five links to screenshots as proof. The screenshots show websites, which allegedly have web shells, a control panel for these web shells, and a list of targets. Currently, it is difficult to say whether this information is true.

The criminal group Oilrig, also known as APT34, has been active since 2015. The group is based in Iran and is believed to be linked with the Iranian government. The threat actors mainly target the banking sector, airlines, educational institutions, government agencies and organisations, and IT and telecommunications companies. They have attacked targets in Saudi Arabia, Turkey, Israel, Kuwait, Qatar, USA, UAE, and Lebanon. The attackers’ main tactic is sending specially crafted emails with a malicious code-containing attachment to companies’ employees.

APT name	Regions attacked	Operation start
APT-C-36	Colombia	April 2018

Since April 2018, APT-C-36 (Blind Eagle), a group believed to originate from South America, has been carrying out targeted attacks on Colombian government institutions and important corporations in the financial sector, petroleum industry, professional manufacturing, etc.

In their attacks, the threat actors disguised as US companies, such as Chevron and Energizer, Abbott Laboratories, and Progressive in order to win their victims’ trust.

360 Threat Intelligence Center analysed a recent Blind Eagle attack, which occurred on 14 February 2019. The group disguised as the Colombian National Civil Registry (Registraduria Nacional del Estado Civil) and used phishing emails to attack the Colombian National Institute for the Blind.

The attackers used proxy and VPN services to hide the sender IP address. The researchers identified that the emails had been sent through IDCs (Internet Database Connectors) in Florida. The email contained a malicious document, which when opened downloaded Imminent Monitor, a RAT that is able to provide remote access to a compromised computer, act as a keylogger, extract passwords from the browser, download, upload and execute PE files, execute scripts, manage proxy, etc.

APT name	Regions attacked	Operation start
Gaza Cybergang	MENA	February 2019

In February 2019, 360 Threat Intelligence Center captured a decoy document designed specifically for Arabic users. It is an Office Word document with malicious macros embedded to drop and execute a backdoor packed by Enigma Virtual Box. The backdoor program has a built-in keyword list containing names of people or opera movies to communicate with C2. The backdoor distributes control commands to further control the victim's device. After investigation, the specialists suspected the attack had been carried out by Molerats.

The backdoor collects information, such as user name and computer name, and a string similar to the UUID. It then encrypts and encodes the information and sends it back to C2.

Gaza Cybergang (Molerats) have been active since 2012 and have been mainly targeting government agencies in the MENA region. The attackers use phishing emails, paste sites hosting malware stages, social engineering methods and different RATs. The group's goal is to collect intelligence data.

APT name	Regions attacked	Operation start
Targeted attack on Australia	Australia	February 2019

At the beginning of February, the Australian Parliament said in a statement that it had experienced a cyberattack on its networks. As reported by the Australian Prime Minister, there was no evidence of any information theft and the attack was promptly isolated and contained by the Australian Cyber Security Centre (ACSC). However, the attackers gained access to the ruling Liberal and National coalition parties' networks as well as the opposition Labor Party just few months before the federal election.

Cybaze-Yoroi ZLab specialists analysed a part of the published data of this incident. All the analysed files seem to be related to a post-exploitation phase, where the attacker leveraged them to conduct data exfiltration and perform lateral movements. None of the modules belonged to an open-source post-exploitation framework, like Metasploit or Empire, but they seem to be written from scratch using the high-level language C# on top of the .NET Framework.

The firstly analysed sample (LazyCat DLL) is malware named LazyCat, mainly derived by the famous Mimikatz penetration testing tool.

Exploring the source code, the specialists noticed a particular module named RottenPotato. It contains some interesting functions, such as findNTLMBytes and HandleMessageAuth, related to the post-exploitation phase in MS Windows environments. It was discovered that it is an open source tool publicly available on GitHub.

During a diff analysis between the Github source code and that of the malware, it emerged that some functions included into malware's RottenPoteto were not present in the open-source code. This indicates that the cyber attacker further weaponised the code to make it more effective for their malicious goal.

The Recon module has two main classes named PortScanner and ReconCommonFuncs and contains an Integer array listing a few of the well-known network ports, covering major local network services such as HTTP, TELNET, RDP, POP, IMAP, SSH, SQL, etc.

For each declared port, the function is able to perform a TCP scan, trying to connect to it. If there is an available service behind the port, it responds with its own service banner, which will be stored in a StringBuilder object. The malware concatenates responses from all scanned ports and writes the results into a file using the ReconCommonFuncs class.

At first, there it was suggested that China was behind the attack, but the information has not been confirmed.

APT name	Regions attacked	Operation start
Goldmouse	The Middle East	March 2019

On 17 March 2019, 360 Threat Intelligence Center captured a target attack sample against the Middle East by exploiting WinRAR vulnerability (CVE-2018-20250[6]), and it seems that the attack was carried out by the Goldmouse APT group (APT-C-27). There is a decoy Word document inside the archive regarding terrorist attacks to lure the victim into decompressing. When the archive gets decompressed on the vulnerable computer, the embedded njRAT backdoor (Telegram Desktop.exe) will be extracted to the startup folder and then triggered into execution if the victim restarts the computer or performs re-login. After that, the attacker is capable to control the compromised device.

The njRAT provides functions such as remote SHELL, plug-in support, remote desktop, file management, etc.

In addition, the specialists discovered multiple related Android samples that disguised as common applications to attack specific targets after performing further investigations.

Considering that the language being used in the malicious code was Arabic, it seems that the attacker is familiar with Arabic language.

APT name	Regions attacked	Operation start
SandCat and FruityArmor exploit the zero-day vulnerability CVE-2019-0797	Global	February 2019

In February 2019, a zero-day vulnerability in Windows (CVE-2019-0797) was discovered. According to the official security bulletin, the problem has to do with win32k component, which fails to properly handle objects in memory. As a result, an attacker with local access could run malicious code in kernel mode, which will allow them to install programs, view, change, or delete data, or create new accounts with full user rights. The problem affected all Windows OS versions, including Windows 10.

Kaspersky Lab notes that the vulnerability has been exploited by at least two APT groups: FruityArmor and SandCat.

FruityArmor is known to have used zero-days before. The experts say that SandCat is a new APT discovered only recently. In addition to CVE-2019-0797 and CHAINSHOT, SandCat also uses the FinFisher/FinSpy framework.

APT name	Regions attacked	Operation start
Chafer	Iran, Turkey	Autumn 2018

Kaspersky Lab reported that throughout autumn 2018 there were attacks on foreign diplomatic entities based in Iran.

The main tool in the campaign is an improved version of Remexi. Remexi boasts features that allow it to gather keystrokes, take screenshots of windows of interest (as defined in its configuration), steal credentials, logons and the browser history, and execute remote commands. Encryption of the configuration file consists of XOR with a hardcoded key. Encryption of data sent from the victims to the C&C server consist of RC4 with a predefined password.

Persistence modules are based on scheduled tasks and system registry. Mechanisms vary for different OS versions.

In November 2018, it was identified that the Chafer threat group targeted a Turkish government entity, reusing the C&C server win10-update[.]com. The payload is Python-based and compiled into executable form using the PyInstaller utility. The code of MechaFlounder, the name Unit42 specialists gave the payload for tracking purposes, is similar to the code of Clayside, which is used by the OilRig group.

MechaFlounder begins by sending an outbound beacon to its C2 server that contains the user's account name and hostname. If the C2 server were to accept the beacon, it would respond to the backdoor with HTML. The backdoor then converts the HTML to text, where it discards the first 10 characters of the response and treats the remainder of the string as a command from the C2 server. The HTML to text code appears to have originated from a discussion at Stack Overflow.

The Chafer threat group has been active since at least 2014. The group's main objective is to collect information that allows them to track targets related to Iran's national priorities or use them as additional accesses to facilitate future campaigns. The group's activities are concentrated in the Middle East. In addition, there are indicators that there have been infections outside the Middle East. Judging by the group's attacks they have prioritized the telecommunications sector, with additional targeting of the travel industry and IT firms that are contractors of the companies the group is interested in.

APT name	Regions attacked	Operation start
Whitefly	Singapore, Southeast Asia, Russia	2017

From mid-2017 to mid-2018, Whitefly launched targeted attacks against multiple organizations. While most of these organisations were based in Singapore, some of them were multinational organizations with presence in Singapore.

Whitefly has attacked organizations in the healthcare, media, telecommunications, and engineering sectors.

The hackers compromise their victims through phishing, using .exe and .dll files disguised as documents or images. The files contain a dropper, which runs a loader known as Trojan.Vcrodat.

When the attackers deliver the DLL file, the malware uses a technique known as search order hijacking to run Vcrodat.

Once executed, Vcrodat loads an encrypted payload on to the victim's computer. The payload contacts a command and control (C&C) domain, sends system information about the infected computer to the C&C server, and downloads additional tools. Whitefly configures multiple C&C domains for each target.

The attackers also used tools such as Mimikatz and an open-source tool that exploits the CVE-2016-0051 vulnerability in Windows.

Whitefly's tools include an open-source hacking tool called Termite (Hacktool.Rootkit) and Nibatad (Infostealer).

Some of the tools Whitefly uses have been deployed in operations targeting organisations outside Singapore, for example, attacks on defence, energy, and telecommunications organisations in Southeast Asia and Russia.

Security specialists first detected Whitefly after an attack on Singapore's largest public health organisation SingHealth, which resulted in a reported 1.5m patient records being stolen.

APT name	Regions attacked	Operation start
Global DNS hijacking campaign	Middle East, North Africa, Europe, North America	January 2017

FireEye specialists identified a DNS hijacking campaign targeting government agencies, Internet and other telecommunications service providers, Internet infrastructure entities, and sensitive commercial organisations across the Middle East, North Africa, North America and Europe. The experts say the campaign was carried out by APTs linked to Iran's government.

Attackers didn't just spear-phish victims to collect email credentials, like most cyber-espionage groups tend to do, but instead modified DNS records for company IT resources to reshape internet traffic inside organizations and hijack the parts they wanted.

The analysts also reported that the hacking group used three different methods in their attacks:

1. The attackers change DNS records for victim's mail server to redirect it to their own email server. Attackers also use Let's Encrypt certificates to support HTTPS traffic, and a load balancer to redirect victims back to the real email server after they have collected login credentials from victims on their shadow server.
2. Same as the first, but the difference is where the company's legitimate DNS records are being modified. In the first technique, the attackers changed DNS A records via an account at a managed DNS provider, while in this technique attackers changed DNS NS records via a TLD (domain name) provider account.
3. Sometimes also deployed as part of the first two techniques. This relies on deploying an "attacker operations box" that responds to DNS requests for the hijacked DNS record. If the DNS request (for a company's mail server) comes from inside the company, the user is redirected to the malicious server operated by attackers, but if the request comes from outside the company, the request is directed to the real email server.

Data leaks

- In February, a hacker nicknamed Gnosticplayers put up for sale a large number of accounts (a total of over 840 million) stolen from hacked resources on Dream Market, an online underground market. Most of the data in the dump are account user names, email addresses and hashed passwords. We should note that the hacker had already put up for sale three dumps, subsequently deleting one of them. The resources the hacker is selling accounts from include Dubsmash (162m accounts), MyFitnessPal (151m), MyHeritage (92m), ShareThis (41m), HauteLook (28m), Animoto (25m), EyeEm (22m), 8fit (20m), Whitepages (18m), Fotolog (16m), 500px (15m), Armor Games (11m), BookMate (8m), CoffeeMeetsBagel (6m), Artsy (1m), and DataCamp (700,000).
- At the beginning of February, it was reported that Bank of India (SBI), India's largest bank, jeopardised millions of users. The problem was that the information from SBI's Quick system (data on the last two months of the system's operation) was stored on an unprotected server. These data contain client account balance and transaction history. The bank was notified about the problem and the vulnerability was patched.
- In March, the FBI said they had discovered that the company Citrix had been hacked. The Iranian hacking group Iridium may be behind the attacks. The details of the investigation have not yet been disclosed, but it is alleged, that the attackers may have gained access to the company's business documents. At the moment, there is no evidence to suggest that the hackers tampered with Citriz software and other products.
- Bob Diachenko, an information security specialist, detected another unprotected MongoDB database with 150GB of personal data. The database comprised 808,539,939 records, containing emails, surnames, information about a person's sex, their date of birth, telephone numbers, postcodes, addresses, and IP addresses. It was established that the database belonged to Verifications IO LLC, an email marketing firm.
- The Californian VoIP provider VOIPO had an unprotected database powered by ElasticSearch with data on the company's clients for at least the last four years. The database contained 6.7m call logs with partial original and destination numbers, timestamps, and call duration details. The oldest call logs were dated July 2017. The server also hosted 6m SMS/MMS messages, including timestamps and the content of the messages. The oldest from them were dated December 2015. In addition, about half a million documents contained API keys for internal systems and sometimes even plaintext user names and passwords.